Lab 37 Worksheet — Physical and Logical Security Control Design

Name: ____ **Date:** __

Exam objective: Select and justify physical and logical security controls for a site, applying the principle of least privilege and defence in depth (Core 2 objectives 2.1 and 2.2).

Record as you go

Step	What you did	What you observed
1	Record the principle of defence in depth: no single control is trusted alone, so controls are layered such that defeating one still leaves the attacker facing another.	
2	List the physical perimeter controls and the threat each defeats: fences and bollards against vehicle and forced entry, lighting against concealment, and cameras against undetected intrusion.	
3	Record the access control vestibule, note that it admits one person at a time, and record that it specifically defeats tailgating and piggybacking.	
4	Distinguish tailgating, where the attacker follows without the employee's knowledge, from piggybacking, where the employee knowingly holds the door.	
5	List the entry controls: badge readers, key fobs, smart cards, conventional keys and biometrics including fingerprint, retina and palm print.	
6	Record the equipment-level controls: cable locks for laptops, locking server racks, lockable equipment cabinets and privacy screens against shoulder surfing.	
7	Record the detection controls: motion sensors	

Step	What you did	What you observed
	including passive infrared, microwave and dual-technology, alarm systems on doors and windows, and guards.	
8	Move to logical controls and record the principle of least privilege: every user gets exactly the access their role requires and no more.	
9	Record the access control list as the mechanism, and note that ACLs are applied on file systems, on network devices and on cloud resources alike.	
10	Record multifactor authentication and its three categories — something you know, something you have and something you are — and state why two passwords do not constitute MFA.	
11	Distinguish a hard token, which is a physical device generating a code, from a soft token, which is an application on a phone, and record the trade-off between them.	
12	Complete the design as a table with every control, its layer, the threat it defeats and its approximate cost, and state which three controls you would implement first on a limited budget.	

Verification

Success criterion: Every control in your design is mapped to a specific threat; tailgating and piggybacking are correctly distinguished; the MFA section correctly rejects two same-category factors; and your first-three prioritisation is justified on risk rather than cost alone.

- I completed every step in the lab.
- My result meets the success criterion above.
- I recorded my evidence (screenshots, output, completed tables).

Reflection

What surprised you in this lab?

Where would you apply this on the job?

What do you still need to revise before the exam?